

ينقسم نظام الصلاحيات في **Cocorra** إلى مستويين متكاملين: (1) أدوار النظام (**System Roles**): صلاحيات الحساب على مستوى الـ API وقاعدة البيانات. (2) أدوار الغرف الصوتية (**Room Roles**): صلاحيات المستخدم التفاعلية داخل الجلسات المباشرة عبر SignalR و LiveKit.

1. جدول الأدوار الشامل (Comprehensive Roles Matrix)

البرول (Role)	المستوى	التعريف والدور في المنصة	الصلاحيات والوظائف الأساسية	أهم القيود والموانع	آلية التعيين
Admin المدير العام	نظام (System)	أعلى سلطة إدارية ورقابية في المنصة مع كامل الصلاحيات لإدارة المستخدمين والأمان والعمليات.	- إدارة الحسابات وحالاتها (Active, Suspended, Banned, Rejected). - حظر الأجهزة والبريد فورياً (BlockDeviceAndEmail). - طرد اتصالات الـ SignalR النشطة فوراً للمحظورين (ForceDisconnect). - إسناد وتعديل أدوار المستخدمين (ManageUserRoles). - معالجة البلاغات وتطبيق العقوبات والدعم المباشر (SupportHub). - استعراض سجل كافة الغرف السابقة (admin/history). - تحليلات الأمان وصحة النظام والـ Backfill والـ MetricsRegistry.	- حصانة الأدمن (Admin Immunity): لا يمكن لأي أدمن معاقبة أو حظر أو تعديل أدوار أدمن آخر. - ممنوع من تعديل حالة حسابه بنفسه أو حظر أجهزته. - لا يُمنح عبر الـ API العادي لمنع التصعيد الذاتي.	يُنشأ عبر IdentitySeeder عند أول تشغيل، أو يدوياً عبر قاعدة البيانات.
Moderator المشرف / المساعد	نظام (System)	رول مساند للأدمن، مسؤول عن الرقابة التشغيلية، حظر المخالفين، فحص البلاغات، وإدارة الدعم الفني.	- استعراض والبحث في قائمة المستخدمين وملفاتهم (AdminController). - تعديل حالات المستخدمين (تنشيط، تجميد، حظر، رفض) وطرد اتصالاتهم فوراً. - حظر الأجهزة والبريد فورياً (BlockDeviceAndEmail). - مراجعة البلاغات وتحديث حالتها واتخاذ إجراءات العقوبة. - استلام الرد على محادثات وتذاكر الدعم الفني الحي (SupportHub).	- حصانة الأدمن (Admin Immunity): يمنع تماماً من اتخاذ أي إجراء عقابي أو حظر أو تعديل ضد أي Admin. - ممنوع من إدارة أدوار النظام (RolesController). - ممنوع من تحليلات المنصة والـ Backfill (AnalyticsController). - ممنوع من الاطلاع على أرشيف الغرف (admin/history).	يُسند للمستخدم بواسطة الـ Admin عبر POST /Api/V1/Roles/ManageUser .
Coach المدرّب / الكوتش	نظام (System)	مستخدم معتمد ومقدم جلسات تدريبية، يمتلك صلاحية إنشاء وإدارة الغرف الصوتية.	- إنشاء الغرف الصوتية العامة والخاصة (يصبح مضيفاً لها Host). - استضافة الجلسات التدريبية وتلقي طلبات المواضيع الخاصة (TargetCoachId).	- ممنوع تماماً من الوصول لمسارات لوحة الإدارة والتحليلات (AdminController و AnalyticsController). - ممنوع من تعديل حالات المستخدمين أو حظر الأجهزة والإيميلات. - ممنوع من إدارة أدوار النظام أو رؤية بلاغات الأمان السرية.	يُسند للحساب بواسطة الـ Admin عبر POST /Api/V1/Roles/ManageUser .
User المستخدم العادي	نظام (System)	المستخدم الأساسي للمنصة وعضو المجتمع عبر تطبيق الموبايل.	- التسجيل، التحقق بالـ OTP وعينة الصوت واختبار الـ MBTI. - إدارة البروفايل، قائمة الأصدقاء، والمحادثات المباشرة (on-1 Chat-1). - استعراض فيد الغرف الصوتية، تفعيل التنبيهات، والانضمام. - إرسال البلاغات وتذاكر الدعم الفني وشات الدعم المباشر.	- ممنوع من إنشاء الغرف الصوتية (محصورة على الكوتش والأدمن فقط). - ممنوع من مسارات لوحة الإدارة أو التحليلات نهائياً (403 Forbidden). - ممنوع من استعراض أدوار النظام أو إدارتها.	يُمنح تلقائياً عند اكتمال التسجيل في AuthServices.RegisterAsync .
Host / Coach مضيف الغرفة الصوتية	غرفة (Room)	منشئ الغرفة أو الكوتش الذي بدأ الغرفة المجدولة، ويمتلك السيطرة الإدارية الكاملة على الجلسة.	- قبول أو رفض طلبات دخول الغرف الخاصة (ApproveUser). - تصعيد المستمعين للمنصة للتحديث (ApproveToStage). - إنزال المتحدثين لمقاعد الجمهور (MoveToAudience). - كتم صوت المتحدثين أو منح وقت إضافي (GrantExtraTime). - طرد المشاركون المساء فوراً من الغرفة (KickUser). - بدء الغرفة وإنهائها رسمياً للجميع (End / Start).	- مقيد بسعة المنصة وسعة الغرفة الكلية. - يخضع لمهلة سماح (GracePeriod) عند انقطاع اتصاله.	من أنشأ الغرفة أو عُين كـ HostId عند إنشائها.
Speaker المتحدث على المنصة	غرفة (Room)	مشارك حصل على إذن وتواجد على منصة التحدث الصوتية (IsOnStage = true).	- نشر الصوت والتحدث للجميع عبر LiveKit كـ Publisher. - التحكم في فتح وكتم المايك الخاص به (ToggleMic). - إرسال رسائل جماعية للغرفة أو همسات خاصة للمشاركين. - النزول من المنصة والعودة للجمهور طواعية.	- مقيد بعداد وقت التحدث الافتراضي للغرفة. - يمكن للهوست كتم صوته أو إنزاله في أي لحظة.	يتم تصعيده بقرار الهوست بعد رفع يده (ApproveToStage).
Listener المستمع / الجمهور	غرفة (Room)	مشارك داخل الغرفة الصوتية في مقاعد الجمهور (IsOnStage = false).	- الاستماع لصوت المتحدثين عبر LiveKit كـ Subscriber. - رفع اليد لطلب التحدث (RaiseHand) أو خفضها. - المشاركة في شات الغرفة أو إرسال همسات للمشاركين. - مغادرة الغرفة في أي وقت (LeaveRoom).	- لا يمكنه فتح المايك أو بث الصوت نهائياً دون إذن. - لا يملك أي صلاحيات طرد أو تحكم في الجلسة.	الحالة الافتراضية لأي مشارك ينضم للغرفة بنجاح.
Pending Approval قيد انتظار الموافقة	غرفة (Room)	مستخدم يطلب الانضمام إلى غرفة صوتية خاصة (Private Room).	انتظار قرار الهوست في قائمة الطرق على الباب (Knocking).	معزول تماماً عن الصوت والشات حتى قبول الهوست له.	تتولد تلقائياً عند محاولة دخول غرفة IsPrivate = true .

2. مصفوفة الصلاحيات حسب ال Endpoints (Endpoint Access Matrix)

جدول توزيع الصلاحيات الدقيقة لكل مسار API و SignalR Hub مع توضيح حصانة الأدمن

د. تحليلات المنصة (AnalyticsController) — /Api/V1/Analytics/					
User	Coach	Mod	Admin	الوظيفة	Endpoint ال
403 ❌	403 ❌	403 ❌	✅	نظرة عامة على نشاط المنصة	GET /Summary
403 ❌	403 ❌	403 ❌	✅	نمو المستخدمين وتوزيع الحالات	GET /Users/Growth
403 ❌	403 ❌	403 ❌	✅	إحصائيات الغرف الصوتية	GET /Rooms
403 ❌	403 ❌	403 ❌	✅	شبكة الاحتفاظ الأسبوعية (Cohorts)	GET /CohortGrid
403 ❌	403 ❌	403 ❌	✅	معدل البلاغات لكل 1,000 انضمام	GET /ReportRate
403 ❌	403 ❌	403 ❌	✅	سرعة مراجعة العينات الصوتية	GET /ReviewLatency
403 ❌	403 ❌	403 ❌	✅	إحصائيات التذاكر ومحادثات الدعم	GET /Support
403 ❌	403 ❌	403 ❌	✅	فحص صحة خط معالجة البيانات	GET /SystemHealth
403 ❌	403 ❌	403 ❌	✅	إعادة تجميع الأرقام التاريخية	POST /Backfill
403 ❌	403 ❌	403 ❌	✅	سجل عقود وتعريف المقاييس	GET /MetricsRegistry
هـ. البلاغات والدعم (SupportController) — /Api/V1/Support/					
User	Coach	Mod	Admin	الوظيفة	Endpoint ال
✅	✅	✅	✅	إرسال بلاغ أو تذكرة مساعدة	POST /Report & /Ticket
✅	✅	✅	✅	إرسال رسالة في شات الدعم الحي	POST /chat/send
403 ❌	403 ❌	✅	✅	استعراض وتصفية بلاغات المستخدمين	GET /admin/reports
403 ❌	403 ❌	*✅	*✅	اتخاذ عقوبة (تحذير، إيقاف، حظر)	POST /admin/reports/{id}/action
403 ❌	403 ❌	✅	✅	استلام شات الدعم والرد عليه	POST /chat/{id}/claim & reply
403 ❌	403 ❌	✅	✅	إنهاء وإغلاق محادثة الدعم	POST /chat/{id}/close
❌	❌	✅	✅	استقبال تنبيهات البلاغات الحية	SupportHub: Admins Group

أ. لوحة الإدارة (AdminController) — /Api/V1/Admin/					
User	Coach	Mod	Admin	الوظيفة	Endpoint ال
403 ❌	403 ❌	✅	✅	استعراض والبحث في المستخدمين	GET /Users
403 ❌	403 ❌	✅	✅	عرض الملف الكامل لمستخدم	GET /User/{id}
403 ❌	403 ❌	✅	✅	إحصائيات لوحة القيادة العامة	GET /Dashboard/Stats
403 ❌	403 ❌	*✅	*✅	تغيير حالة مستخدم + طرد اتصاله	PUT /User/ChangeStatus/{id}
403 ❌	403 ❌	*✅	*✅	تغيير جماعي لحالات مستخدمين	PUT /Users/BulkChangeStatus
403 ❌	403 ❌	*✅	*✅	حظر الجهاز والإيميل والحساب	POST /BlockDeviceAndEmail

* خاضع لـ Admin Immunity: يرفض النظام برمجياً اتخاذ أي إجراء ضد أي حساب يحمل رول Admin.

ب. إدارة الأدوار (RolesController) — /Api/V1/Roles/					
User	Coach	Mod	Admin	الوظيفة	Endpoint ال
403 ❌	403 ❌	403 ❌	✅	عرض قائمة كافة أدوار النظام	GET /List
403 ❌	403 ❌	403 ❌	✅	عرض تفاصيل دور محدد	GET /{id}
403 ❌	403 ❌	403 ❌	*✅	إسناد وإزالة أدوار للمستخدمين	POST /ManageUser
403 ❌	403 ❌	403 ❌	✅	عرض المستخدمين في دور معين	GET /Users/{roleName}

ج. الغرف الصوتية (RoomHub & RoomsController)	
الإجراء / المسار	الصلاحيات والمسؤول المسموح له
POST /Api/V1/Room/Create	Admin و Coach فقط (مستخدم عادي أو مشرف: 403 Forbidden).
POST /End & POST /Start	Host الغرفة فقط لبدء أو إنهاء الجلسة.
GET /admin/history	Admin النظام فقط لاستعراض أرشيف الغرف المنتهية.
RoomHub.ApproveToStage / MoveToAudience	Host الغرفة فقط للتحكم في مقاعد المنصة.
RoomHub.GrantExtraTime / KickUser	Host الغرفة فقط لمنح وقت أو طرد مشارك.
RoomHub.ToggleMic	المتحدثين على المنصة أو الهوست فقط.

3. القواعد والاعتبارات الأمنية (Security & Architecture Highlights)

السياسات الأمنية، حصانة الأدمن، آليات الرقابة، وإدارة الجلسات الحية في الباك إند

1. منع التصعيد الذاتي (No Elevation)

تم تحسين نقطة النهاية `ManageUserRolesAsync` برمجياً في الـ BLL بحيث ترفض صراحة إستناد رول `Admin` لأي حساب.

- تعيين `Admin` يتم حصرياً عبر `IdentitySeeder` عند إقلاع السيرفر أو يدوياً عبر قاعدة البيانات.
- يُمنع أي `Admin` من تعديل حالة حسابه بنفسه لمنع تعطيل الإدارة.

2. عزل الاتصالات الفوري (ForceDisconnect)

نظراً لكون توكينات الـ JWT بطبيعتها عديمة الحالة (Stateless) ولا يمكن إبطالها لحظياً قبل انتهاء صلاحيتها:

- عند تغيير حالة أي مستخدم إلى `Banned` أو `Rejected`، أو طلب `BlockDeviceAndEmail`.
- يقوم النظام بحصر كافة اتصالات الـ SignalR في `RoomHub` وبث رسالة `ForceDisconnect` وقطع السوكيت فوراً لطرده.

3. حصانة الأدمن (Admin Immunity)

حماية صارمة على مستوى طبقة الخدمات (BLL) تمنع استهداف أي حساب يحمل رتبة `Admin`:

- Moderator vs Admin**: لا يستطيع المشرف حظر الأدمن أو تغيير حالته أو أجهزته أو اتخاذ إجراء ضده.
- Admin vs Admin**: لا يستطيع أي مدير معاقبة مدير آخر أو تعديل أدواره منعاً للنزاعات الداخلية.
- تم الفحص والتحقق عبر `IsInRoleAsync(user, "Admin")` في كافة الخدمات الإدارية.

4. حماية انقطاع الكوتش (Host Grace)

في الغرف الصوتية، انقطاع اتصال الهوست مؤقتاً بسبب تذبذب الشبكة لا ينهي الغرفة فوراً:

- تدخل الغرفة في مهلة سماح `HostReconnectGraceSeconds` مع عد تنازلي للجمهور.
- إذا لم يعد الهوست قبل انتهاء المهلة، تقوم خدمة خلفية `HostReconnectGraceService` بإغلاق الغرفة تلقائياً لحماية الموارد.

ملخص تدفق الصلاحيات حسب نوع الحساب (Identity Summary)

نوع الرول	الوصول لبيانات التطبيق	الوصول للوحة الإدارة (Admin Panel)	التحكم في الغرف الصوتية
Admin	كامل البيانات والتقارير والشكاوى الحساسة	كامل الصلاحيات (حظر، تغيير حالات، أدوار، أجهزة) + خاضع لحصانة الأدمن	أرشفيف الغرف الشامل وإمكانية استضافة الغرف الصوتية
Moderator	بيانات المستخدمين، البلاغات، محادثات وتذاكر الدعم	صلاحيات إشرافية (حظر أجهزة ومستخدمين، بلاغات، دعم) + محمي بعدم المساس بالأدمن	مشارك عادي في الغرف (لا ينشئ غرفاً إلا إذا امتلك رول Coach)
Coach	بياناته الشخصية، والغرف الخاصة به والجلسات	ممنوع تماماً (Forbidden 403) على جميع مسارات الإدارة والتحليلات	إنشاء وإدارة الغرف الخاصة به، تصعيد المتحدثين، طرد المسبيء
User	بياناته الشخصية، الأصدقاء، الغرف العامة	ممنوع تماماً (Forbidden 403) على جميع المسارات الإدارية	استماع، رفع اليد، التحدث عند القبول (ممنوع من إنشاء غرف)